

Security Best Practices for Bastion Host Architecture

1. Restrict SSH Access

Never allow:

SSH → 0.0.0.0/0

Instead:

SSH → Specific Public IP (/32)

This reduces exposure to unauthorized access attempts.

2. Use Bastion Hosts

Do not expose private servers directly to the internet.

Recommended architecture:

Laptop ↓ Bastion Host ↓ Private Servers

This minimizes attack surface.

3. Use Security Group Referencing

Instead of allowing entire IP ranges:

Private EC2 SSH → bastion-sg

This ensures only approved resources can communicate.

4. Disable Public IPs for Private Instances

Private servers should not receive public IP addresses.

Benefits:

- Reduced attack surface
 - Better network isolation
 - Improved security posture
-

5. Use SSH Agent Forwarding

Avoid copying private keys to cloud servers.

Benefits:

- Private keys remain on local machine
 - Reduced risk of credential leakage
 - Easier key management
-

6. Follow Least Privilege Principle

Grant only the minimum permissions required.

Example:

- Bastion Host: SSH access only
 - Private EC2: Access only from Bastion Host
-

7. Monitor Access Logs

Review:

- SSH login activity
- Failed authentication attempts
- Security group changes

Regular monitoring helps identify suspicious activity.

8. Remove Unused Resources

Delete:

- Unused EC2 instances
- Unused Elastic IPs

- Unused Security Groups

This reduces cost and security risks.

Conclusion

Following these security practices ensures a secure AWS environment while maintaining controlled administrative access to private infrastructure.